Estudo Dirigido 02

Projeto Banco de Dados Seguro

Administração de banco de dados

Integrantes:

- Adriano Antônio Nogueira de Paula
- Bernardo Ladeira Leal de Medeiros
- Igor Landim Oliveira
- João Hugo Teixeira Martins Botelho
- Mateus Silva Xavier
- Pedro Paiva Ferreira
- Pedro Sias Ferreira

---

1. Introdução

Para o presente trabalho foi desenvolvido um Sistema de Biblioteca, utilizando o Sistema Gerenciador de Banco de Dados (SGBD) Microsoft SQL Server, por meio da ferramenta Microsoft SQL Server Management Studio (SSMS). A escolha dessas tecnologias se justifica pela sua ampla utilização no mercado, robustez, confiabilidade e suporte a recursos avançados de gerenciamento e segurança de dados.

No contexto atual, em que sistemas de informação lidam constantemente com dados sensíveis, a segurança em banco de dados torna-se um requisito essencial. A ausência de mecanismos adequados de controle de acesso pode resultar em falhas graves, como exposição de informações confidenciais, inconsistência de dados e acessos não autorizados. Dessa forma, este trabalho busca demonstrar, de forma aplicada, a implementação de práticas básicas de segurança, incluindo controle de permissões, restrição de acesso, criptografia de dados e auditoria de operações.

2. Planejamento do Banco de Dados

O planejamento do banco de dados foi realizado considerando a necessidade de garantir não apenas a organização e integridade dos dados, mas também a segurança das informações armazenadas.

Inicialmente, foram definidos diferentes perfis de usuários, com o objetivo de segmentar o acesso ao sistema conforme o nível de responsabilidade e necessidade de uso. Foram estabelecidos dois perfis principais: o usuário administrador (admin_biblioteca), responsável pela gestão completa do banco de dados, e o usuário comum (usuario_comum), com acesso restrito às informações.

A definição dos níveis de acesso foi baseada no princípio do menor privilégio, no qual cada usuário possui apenas as permissões estritamente necessárias para desempenhar suas funções. Dessa forma, o administrador possui permissões completas de leitura e escrita, enquanto o usuário comum possui acesso limitado, essencialmente para consulta de dados não sensíveis.

Durante o planejamento, foram identificados como dados sensíveis aqueles relacionados aos usuários do sistema, incluindo informações pessoais e, principalmente, credenciais de acesso. Esses dados exigem tratamento diferenciado, visando evitar exposição indevida.

As regras de segurança adotadas incluíram:

- utilização de roles para agrupamento de permissões;
- restrição de acesso direto a tabelas críticas;
- controle granular de operações (SELECT, INSERT, UPDATE, DELETE);
- implementação de criptografia para proteção de senhas;
- utilização de views para limitar a visualização de dados;
- criação de mecanismos de auditoria para rastreamento de ações no sistema.

3. Implementação da Segurança

A implementação da segurança no banco de dados foi realizada utilizando recursos nativos do Microsoft SQL Server, com foco na criação de usuários, definição de papéis (roles), atribuição de permissões e proteção de dados sensíveis.

Inicialmente, foram criados usuários no SGBD, vinculados a logins previamente definidos. Esses usuários foram posteriormente associados a roles específicas, permitindo uma administração mais eficiente das permissões.

A utilização de roles mostrou-se uma estratégia eficaz, uma vez que possibilita a centralização das permissões, evitando a necessidade de atribuição individual para cada usuário. Foram criadas duas roles principais: role_admin, com permissões completas, e role_leitura, com permissões restritas.

Para o controle de acesso, foram utilizados comandos da linguagem DCL (Data Control Language), especialmente GRANT, REVOKE e DENY. O comando GRANT foi utilizado para conceder permissões específicas de acesso a objetos do banco, enquanto o REVOKE foi

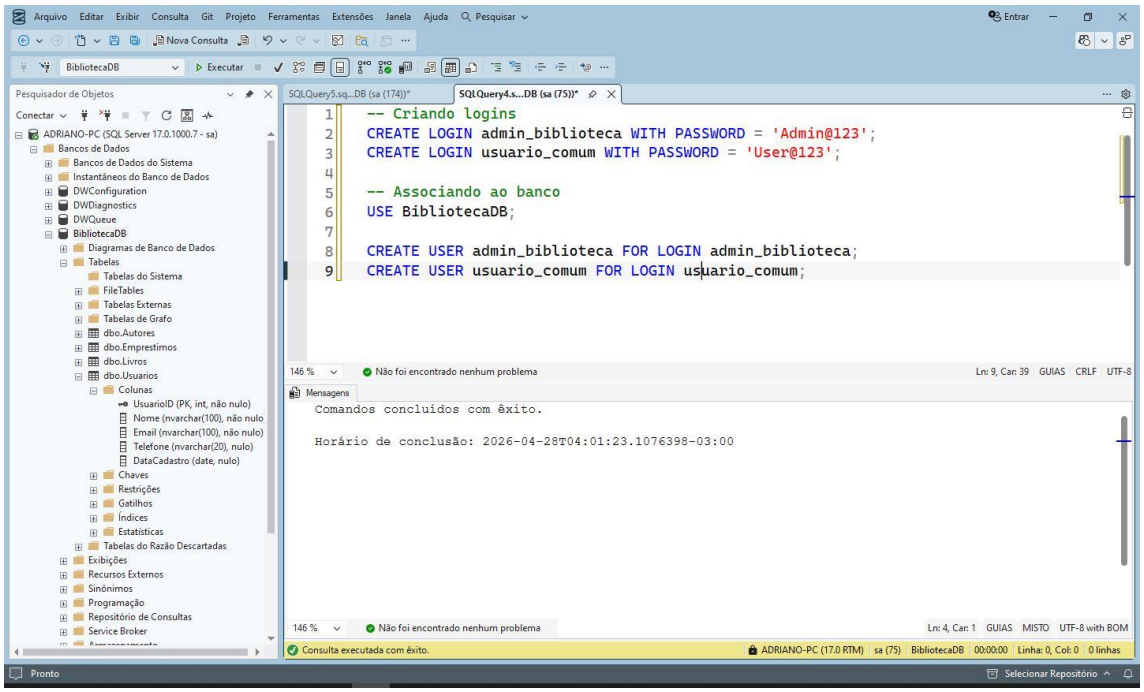
empregado para remover permissões previamente atribuídas. Já o comando DENY foi utilizado para bloquear explicitamente o acesso a determinados recursos, mesmo que permissões tenham sido concedidas indiretamente.

A definição de permissões foi realizada de forma criteriosa, garantindo que apenas o administrador tivesse acesso completo às tabelas do sistema, enquanto o usuário comum foi limitado a operações de leitura em tabelas específicas e acesso a uma view controlada.

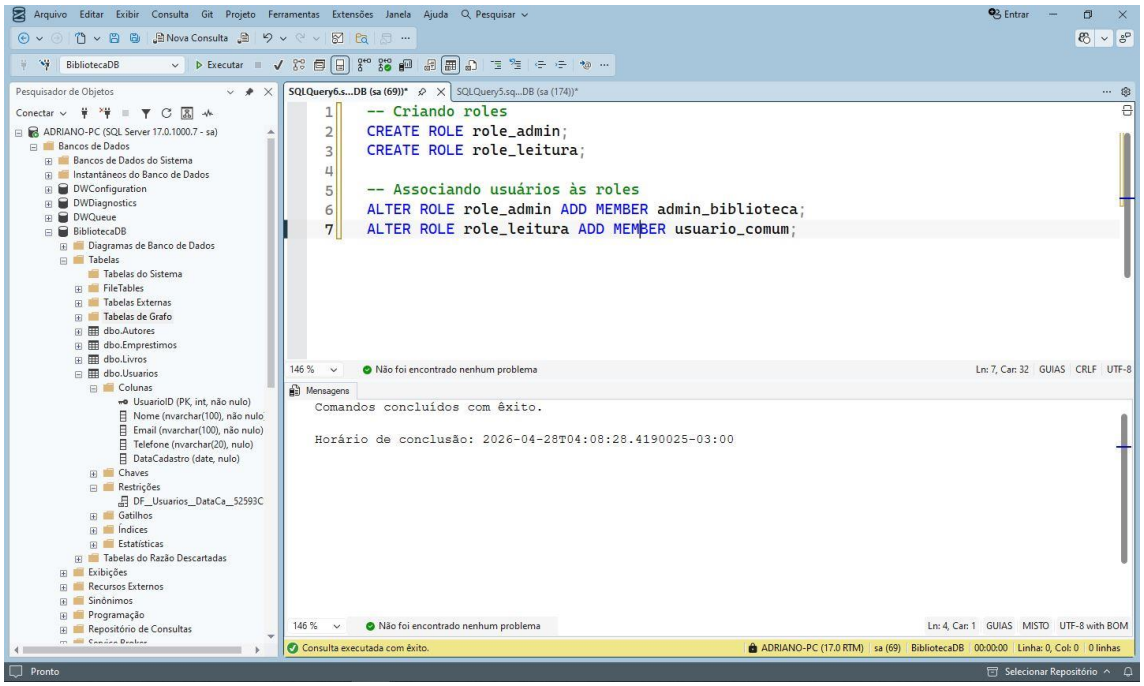
No que se refere à proteção de dados sensíveis, foi implementado o armazenamento de senhas utilizando criptografia por meio da função HASHBYTES com o algoritmo SHA-256. Esse método garante que as senhas não sejam armazenadas em formato legível, aumentando significativamente a segurança contra acessos indevidos e vazamentos de dados.

Além disso, foi criada uma view (VW_Usuarios_Publico) com o objetivo de restringir a visualização de informações sensíveis, permitindo que usuários comuns tenham acesso apenas a dados essenciais, como nome e e-mail.

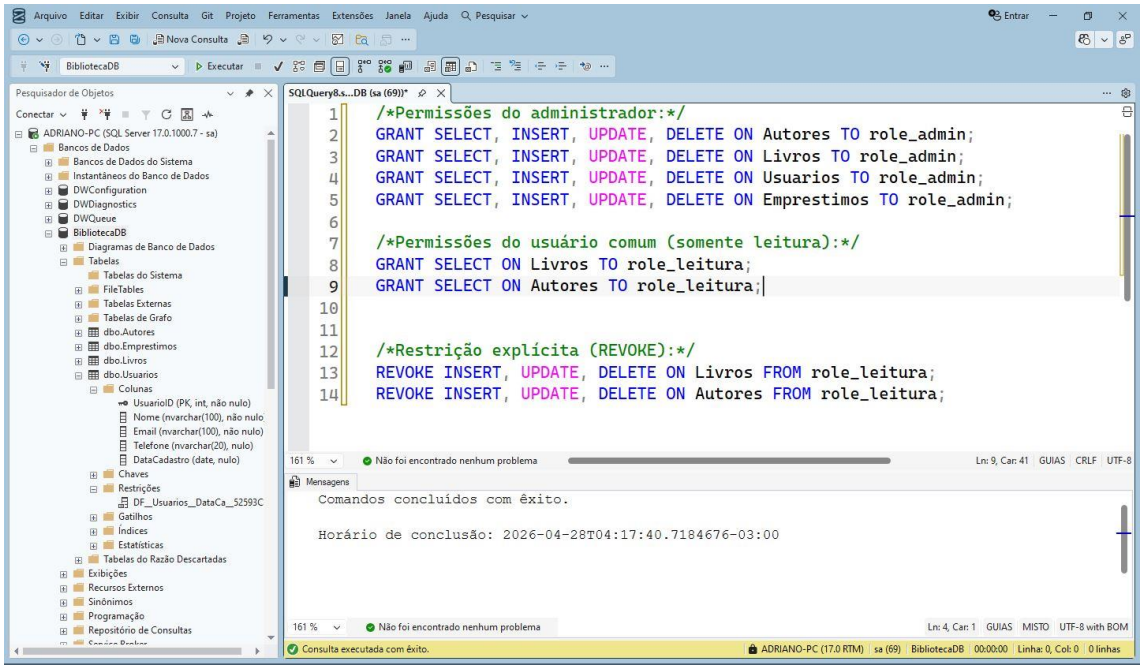
3.1 - Criação de Usuários no SGBD.



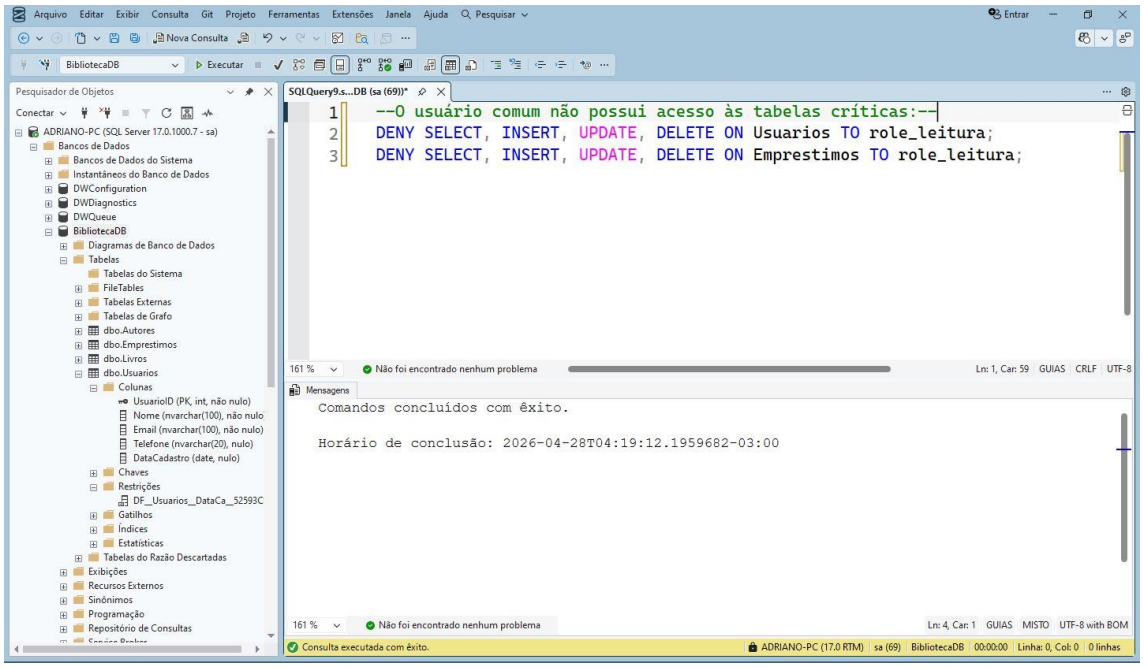
3.2 - Definição de Perfis de Acesso (Roles).



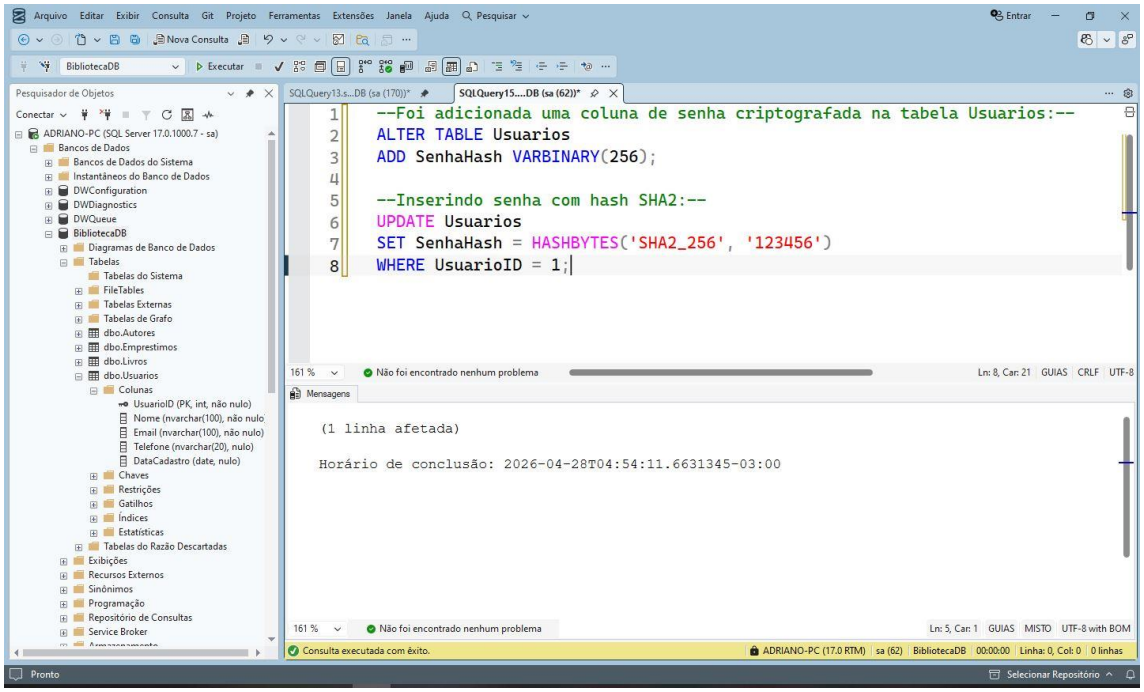
3.3 - Utilização de GRANT e REVOKE atribuindo acesso completo ao administrador e restrições ao usuário comum.



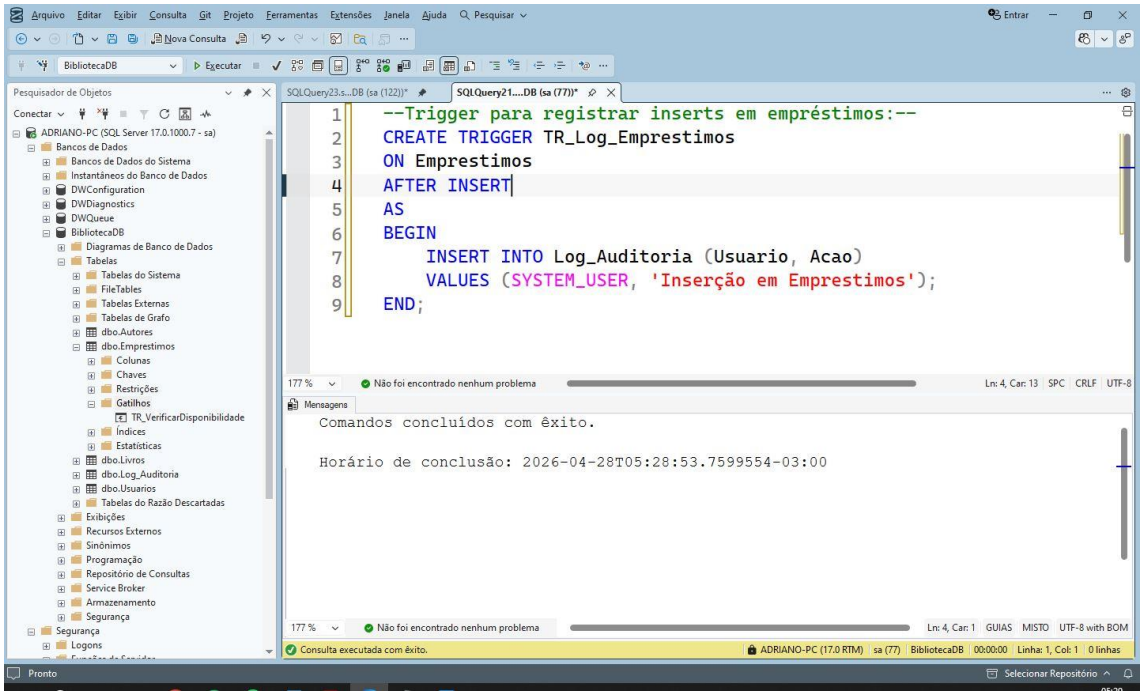
3.4 - Aplicação de DENY para restrição a tabelas sensíveis, impedindo que usuários com permissões limitadas manipulem esses dados.



3.5 - Proteção de Dados Sensíveis (Criptografia de Senha).



3.6 - Auditoria Simples (Registro de Ações) Trigger.



4. Controle de Acesso

O controle de acesso foi estruturado com base na diferenciação clara entre os perfis de usuários e nas permissões atribuídas a cada role.

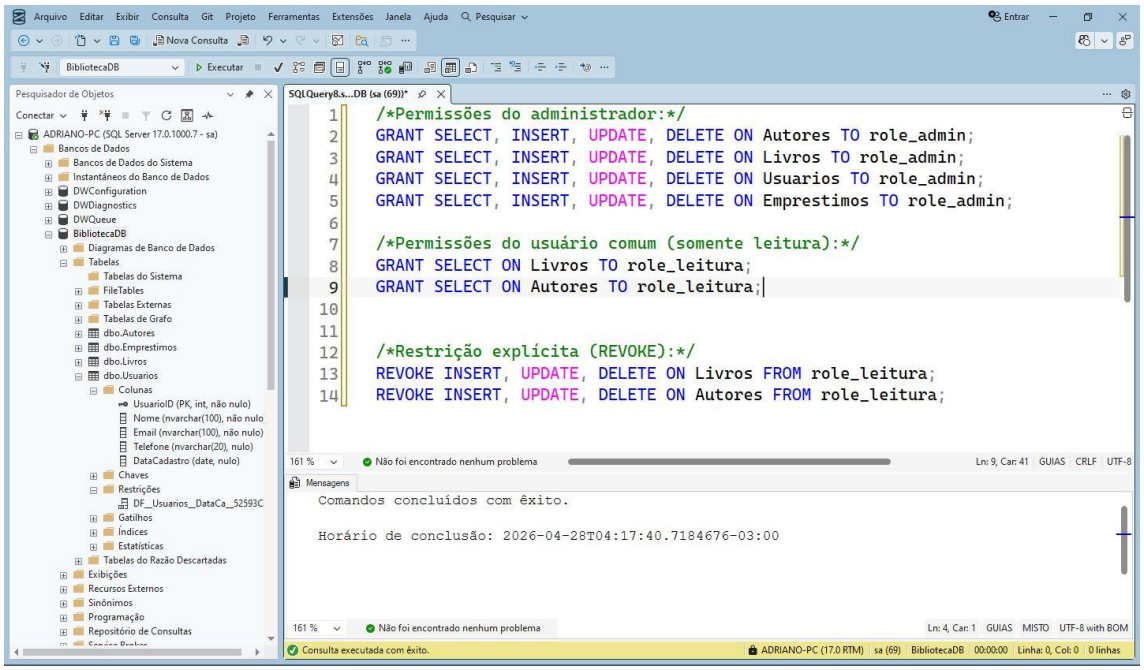
O usuário administrador possui acesso irrestrito às tabelas do banco de dados, podendo realizar operações de inserção, atualização, exclusão e consulta. Essa configuração é necessária para permitir a manutenção e o gerenciamento completo do sistema.

Por outro lado, o usuário comum possui acesso limitado, sendo autorizado apenas a realizar consultas em tabelas não sensíveis, como Autores e Livros. O acesso à tabela Usuarios é restrito, sendo permitido apenas por meio da view VW_Usuarios_Publico, que oculta informações consideradas confidenciais.

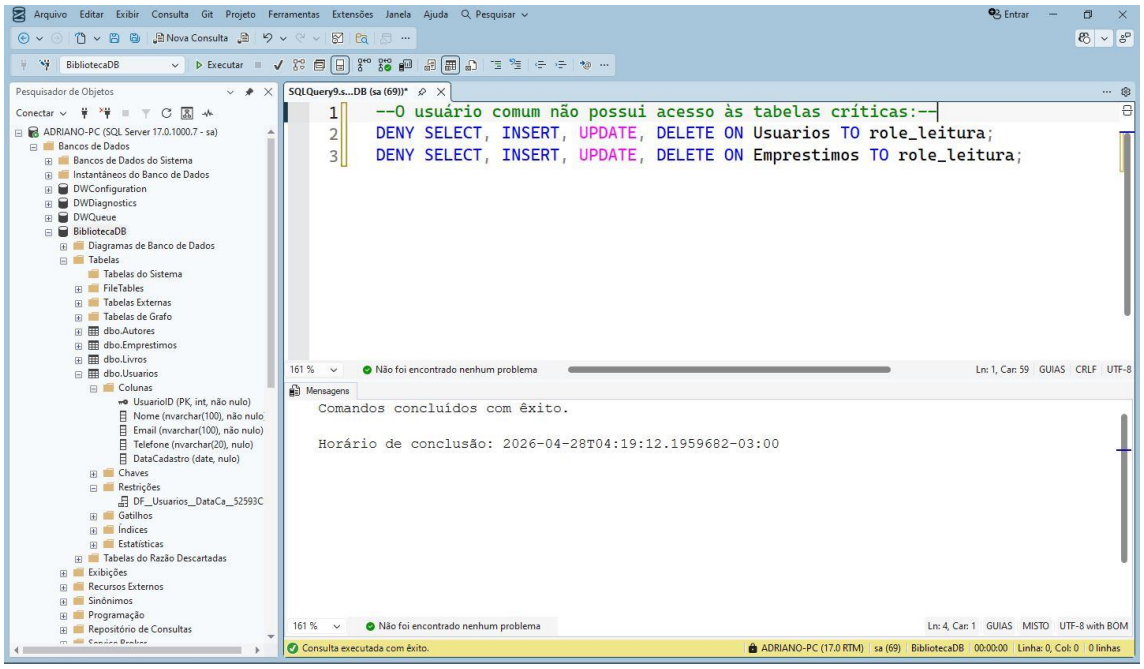
A diferença entre as permissões concedidas evidencia a aplicação do princípio do menor privilégio, garantindo que usuários não tenham acesso a informações ou operações que não sejam necessárias para suas funções.

Como exemplo prático, ao tentar realizar operações de inserção ou atualização em tabelas restritas, o usuário comum recebe uma mensagem de erro indicando permissão negada, demonstrando a efetividade das políticas de controle de acesso implementadas.

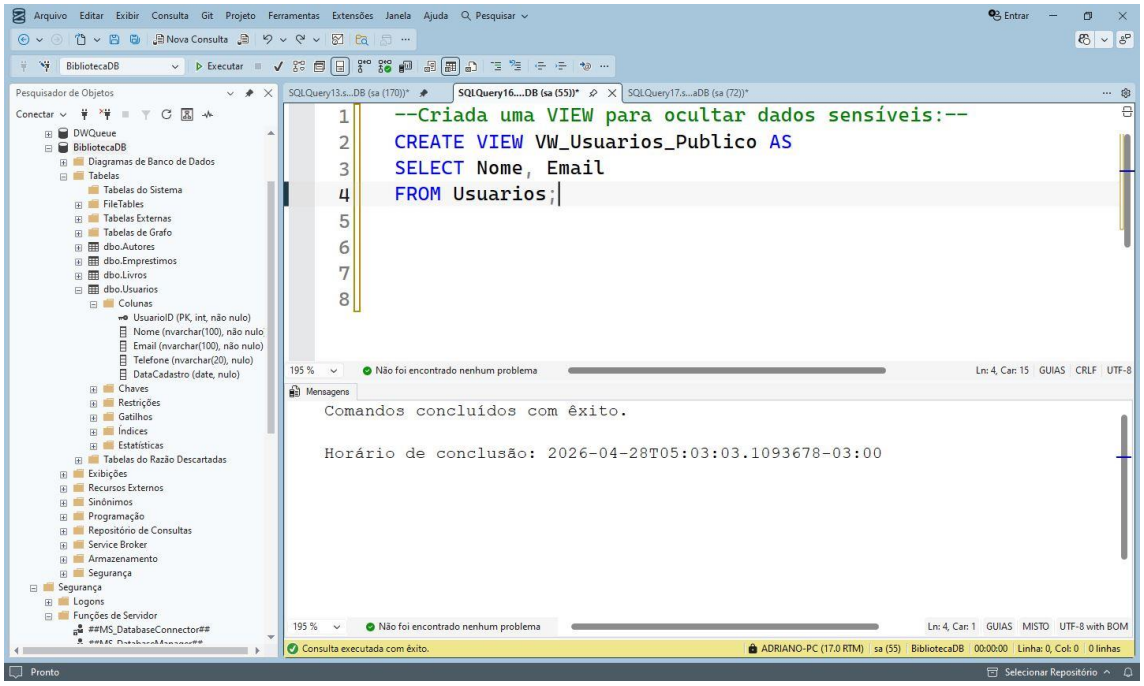
4.1 - Diferenciação de permissões entre os perfis de usuários, destacando a limitação de operações do usuário comum e o controle de acesso aplicado às tabelas do sistema.



4.2 - Restrição aplicada ao usuário comum, impossibilitando acesso sobre tabelas críticas e reforçando controle.



4.3 - Uso de VIEW para Restrição de Dados.



5. Testes de Integridade

Com o objetivo de validar as regras de segurança implementadas, foram realizados diversos testes práticos no ambiente do SGBD.

Entre os testes executados, destacam-se:

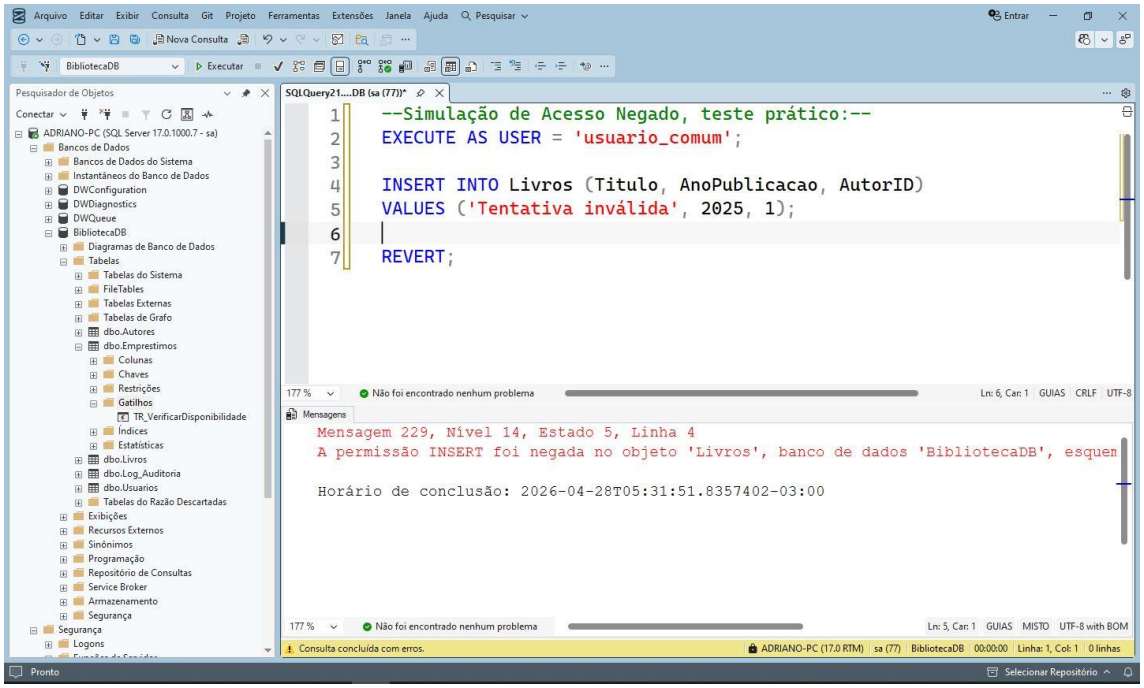
- verificação de acesso permitido para operações de leitura realizadas pelo usuário comum;
- tentativa de execução de operações de escrita (INSERT, UPDATE e DELETE) por usuários sem permissão;
- validação das restrições impostas às tabelas sensíveis;
- execução de procedimentos armazenados para registro de empréstimos;
- verificação do funcionamento de triggers associadas à auditoria.

Os testes demonstraram que o sistema responde adequadamente às tentativas de acesso não autorizado, bloqueando operações indevidas e garantindo a integridade dos dados.

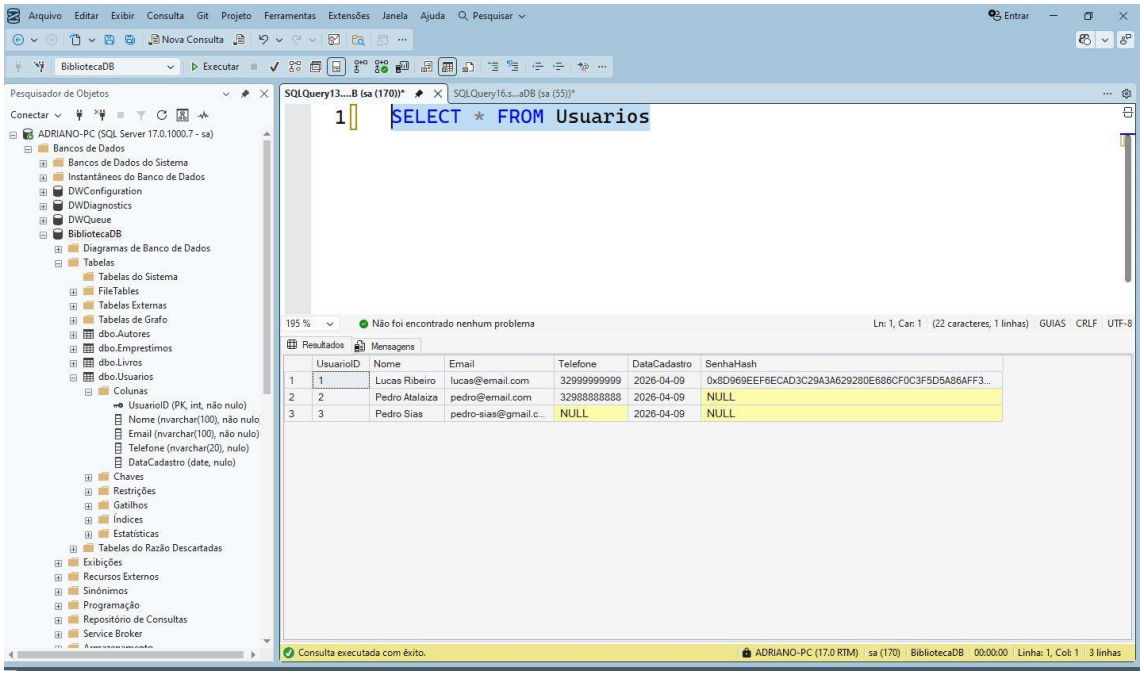
Adicionalmente, foi possível verificar o funcionamento da criptografia de senhas, observando-se que os valores armazenados na base de dados encontram-se em formato binário, impossibilitando sua leitura direta.

A auditoria também foi validada por meio da inserção de registros na tabela de empréstimos, que geraram automaticamente entradas na tabela de log, permitindo o rastreamento das ações realizadas no sistema.

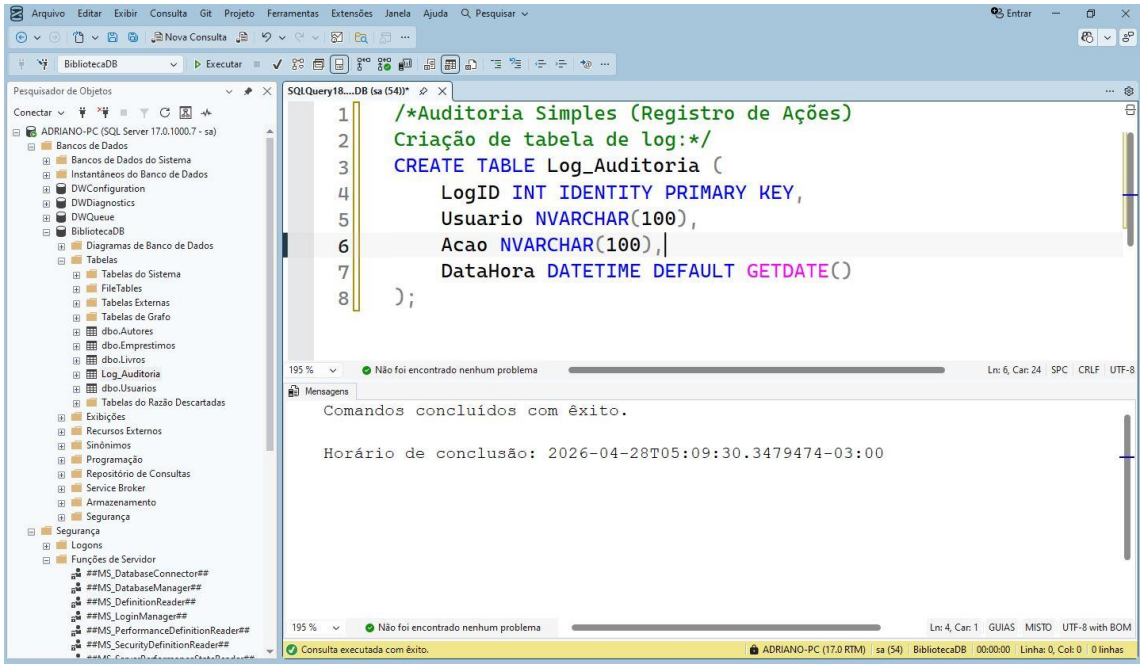
5.1 - Simulação de Acesso Negado.



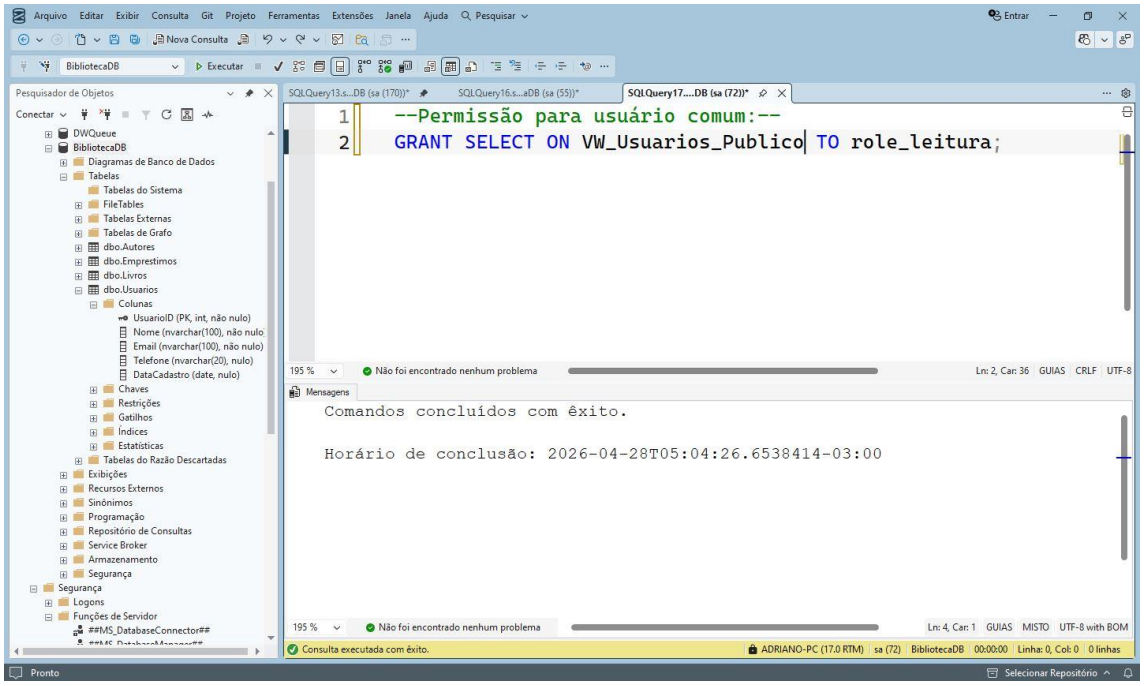
5.2 - Comprovação que a tabela *Usuarios* recebeu criptografia de senha por HASHBYTES.



5.3 - Auditoria Simples (Registro de Ações).



5.4 - Uso de VIEW para Restrição de Dados.



6. Formato e Execução

O desenvolvimento e a execução do projeto foram realizados utilizando o Microsoft SQL Server como SGBD e o Microsoft SQL Server Management Studio (SSMS) como ferramenta de gerenciamento.

Foram elaborados scripts SQL contendo todas as etapas do processo, incluindo:

- criação do banco de dados;
- definição das tabelas e seus relacionamentos;
- implementação de constraints de integridade;
- criação de usuários e roles;
- definição de permissões com GRANT, REVOKE e DENY;
- implementação de views e triggers;
- inserção e manipulação de dados para testes.

Os testes de segurança foram executados diretamente no ambiente do SSMS, utilizando diferentes contextos de usuário, o que possibilitou simular cenários reais de acesso ao sistema e validar o comportamento das regras implementadas.

7. Conclusão

O desenvolvimento deste trabalho permitiu a aplicação prática de conceitos fundamentais relacionados à segurança em bancos de dados, evidenciando a importância de um planejamento adequado e da correta implementação de mecanismos de controle de acesso.

Durante a execução, foram enfrentadas dificuldades relacionadas principalmente à configuração de permissões, compreensão do contexto de execução no SGBD e organização dos scripts. Tais desafios contribuíram significativamente para o processo de aprendizagem.

A experiência adquirida reforça a importância da adoção de boas práticas de segurança, como a utilização de roles, restrição de acessos, proteção de dados sensíveis e auditoria de operações. Esses mecanismos são essenciais para garantir a confidencialidade, integridade e disponibilidade das informações.

Conclui-se que a segurança em banco de dados não deve ser tratada como um elemento secundário, mas sim como parte integrante do desenvolvimento de sistemas, sendo fundamental para a confiabilidade e proteção dos dados em ambientes computacionais.

Link ou repositório contendo o projeto

- https://github.com/AdrianoNog95/Trabalho-adm-banco-de-dados